

Between May and July 2017, American credit bureau Equifax was breached. Private records of 147.9 million Americans along with 15.2 million British citizens and about 19,000 Canadian citizens were compromised in the breach, making it one of the largest cybercrimes related to identity theft. Equifax discovered the breach at the end of July, but did not disclose it to the public until September 2017. In a settlement with the United States Federal Trade Commission, Equifax offered affected users settlement funds and free credit monitoring.

In February 2020, the United States government indicted members of China's People's Liberation Army for hacking into Equifax and plundering sensitive data as part of a massive heist that also included stealing trade secrets, though the Chinese Communist Party denied these claims.

Data breach

Information accessed in the breach included first and last names, Social Security numbers, birth dates, addresses, and, in some instances, driver's license numbers for an estimated 143 million Americans, based on Equifax' analysis.

Information on almost 14 million British residents was also compromised, as well as 8,000 Canadian residents. An additional 11,670 Canadians were affected as well, later revealed by Equifax. Credit card numbers for approximately 209,000 U.S. consumers, and certain dispute documents with personally identifiable information for approximately 182,000 U.S. consumers were also accessed.

Background

An Equifax internal audit in 2015 revealed a significant backlog of unresolved vulnerabilities. The audit found that Equifax was not adhering to its own patching schedules, IT staff lacked a comprehensive asset inventory, and the company did not prioritise patches based on the criticality of IT assets. Additionally, the patching process relied on an honour system, without

strict enforcement. The report outlined actions to improve security measures, but by the time of the breach two years later, many had not been implemented.

A key security patch for Apache Struts, a web application framework, was released on March 7, 2017, after a critical security vulnerability was identified, and all users of the framework were urged to update immediately. Security experts detected a hacking group of unidentified origin scanning for websites that had not updated Struts as early as March 10, 2017.

Intrusion

The Equifax data breach began on May 12, 2017, when Equifax had not yet updated its credit dispute website with the latest version of Apache Struts. Exploiting this vulnerability, hackers gained access to internal servers within Equifax's corporate network. Initially, they obtained internal credentials for Equifax employees, enabling them to access and query the credit monitoring databases while appearing as authorized users. Using encryption to further mask their searches, the hackers performed more than 9,000 scans of the databases. They extracted information into small temporary archives, exfiltrated them from Equifax servers to evade detection, and deleted the archives after extraction. The intrusion continued undetected for 76 days until July 29, 2017, when Equifax discovered the breach.

This breach was also largely possible due to the default username and password of "admin" and lack of two-factor authentication on high-access accounts. This let the hackers gain access with proper authentication to avoid detection as they continued with their exploits on the server. This, along with other major security violations, was the basis of the 2019 Class Action Lawsuit.

Discovery

On July 29, 2017, Equifax's internal IT team updated a Secure Sockets Layer (SSL) certificate for an application that monitored inbound and outbound network traffic. The SSL certificate

allowed the application to decrypt outgoing traffic to analyze it. Once the new SSL certificate was installed, the application alerted Equifax employees to suspicious network activity. The certificate had been expired for nine months.

By July 30, Equifax had shut down the exploit. At least 34 servers in 20 different countries were used at various points during the breach, complicating efforts to track the perpetrators. While the failure to update Apache Struts was a significant issue, analysis of the breach identified additional security weaknesses that contributed to the incident. These included an insecure network design that lacked sufficient segmentation, potentially inadequate encryption of personally identifiable information (PII), and ineffective breach detection mechanisms.

Disclosure and short-term responses

On September 7, 2017, Equifax disclosed the breach and its scope, which affected over 140 million Americans. VentureBeat called the exposure of data on more than 140 million customers "one of the biggest data breaches in history." Equifax shares dropped 13% in early trading the day after the breach was made public. Numerous media outlets advised consumers to request a credit freeze to reduce the impact of the breach.

On September 10, 2017, three days after Equifax revealed the breach, Congressman Barry Loudermilk (R-GA), who had been given two thousand dollars in campaign funding from Equifax, introduced a bill to the U.S. House of Representatives that would reduce consumer protections in relation to the nation's credit bureaus, including capping potential damages in a class action suit to \$500,000 regardless of class size or amount of loss. The bill would also eliminate all punitive damages. Following criticism by consumer advocates, Loudermilk agreed to delay consideration of the bill "pending a full and complete investigation into the Equifax breach".

On September 15, Equifax released a statement announcing the immediate departures and replacements of its chief information officer and chief security officer. The statement included

bullet-point details of the intrusion, its potential consequences for consumers, and the company's response. The company said it had hired cybersecurity firm Mandiant on August 2 to investigate the intrusion internally. The statement did not specify when U.S. government authorities were notified of the breach, although it did assert "the company continues to work closely with the FBI in its investigation".

On September 26, Equifax announced the retirement of CEO Richard Smith, 57, who agreed to remain as an unpaid advisor to assist in the transition to a new CEO.

On September 28, new Equifax CEO Paulino do Rego Barros Jr. responded to criticism of Equifax by promising that the company would, from early 2018, allow "all consumers the option of controlling access to their personal credit data", and that this service would be "offered free, for life".

On October 26, Equifax appointed technology executive Scott A. McGregor to its board of directors. In announcing the change, the board's chairman noted McGregor's "extensive data security, cybersecurity, information technology and risk management experience". The Wall Street Journal reported that he joined the board's technology committee, which has duties that include oversight of cybersecurity.

Aftermath

Since the initial disclosure in September 2017, Equifax expanded the number of records they discovered were accessed. In both October 2017 and March 2018, Equifax reported that an additional 2.5 and 2.4 million American consumer records were accessed, respectively, bringing the total to 147.9 million. Equifax narrowed its estimate for UK consumers affected by the breach to 15.2 million in October 2017, of which 693,665 had sensitive personal data disclosed. Equifax also estimated that the number of drivers' licenses breached in the attack to be 10-11 million.

Security experts expected that the lucrative private data from the breach would be turned

around and sold on black markets and the dark web, though as of May 2021, there has been no sign of any sale of this data. Because the data did not immediately show up in the first 17 months following the breach, security experts theorized that either the hackers behind the breach were waiting for a significant amount of time before selling the information since it would be too "hot" to sell that close to the breach, or that a nation-state was behind the breach and planning on using the data in a non-financial manner such as for espionage.

Litigation and fines

Numerous lawsuits were filed against Equifax in the days after the disclosure of the breach. In one suit the law firm Geragos & Geragos has indicated they would seek up to \$70 billion in damages, which would make it the largest class-action suit in U.S. history. Since October 2017, hundreds of consumers have sued Equifax for the data breach, some winning small claims cases in excess of \$9,000, including actual damages, future damages, anxiety, monitoring fees and punitive damages.

In September 2017, Richard Cordray, then director of the Consumer Financial Protection Bureau (CFPB), authorized an investigation into the data breach on behalf of affected consumers. However, in November 2017, Mick Mulvaney, President Donald Trump's budget chief, who was appointed by Trump to replace Cordray, was reported by Reuters to have "pulled back" on the probe, along with shelving Cordray's plans for on-the-ground tests of how Equifax protects data. The CFPB also rebuffed bank regulators at the Federal Reserve Bank, Federal Deposit Insurance Corporation and Office of the Comptroller of the Currency who offered to assist with on-site exams of credit bureaus. Senator Elizabeth Warren, who released a report on the Equifax breach in February 2018, criticized Mulvaney's actions, stating: "We're unveiling this report while Mick Mulvaney is killing the consumer agency's probe into the Equifax breach. Mick Mulvaney shoots another middle finger at consumers."

On July 22, 2019, Equifax agreed to a settlement with the Federal Trade Commission (FTC),

CFPB, 48 U.S. states, Washington, D.C., and Puerto Rico to alleviate damages to affected individuals and make organizational changes to avoid similar breaches in the future. The total cost of the settlement included \$300 million to a fund for victim compensation, \$175 million to the states and territories in the agreement, and \$100 million to the CFPB in fines. In July 2019, the FTC published information on how affected individuals could file a claim against the victim compensation fund using the website [EquifaxBreachSettlement.com](https://www.equifaxbreachsettlement.com).

In the UK, the Financial Conduct Authority imposed a financial penalty of £11,164,400 for failing to protect the information of UK consumers.

Perpetrators

The United States Department of Justice announced on February 10, 2020 that they had indicted four members of China's military on nine charges related to the hack, though there has been no additional evidence that China has since used the data from the hack. The Chinese government denied that the four accused had any involvement with the hack.

Criticism

Following the announcement of the May–July 2017 breach, Equifax's actions received widespread criticism. Equifax did not immediately disclose whether PINs and other sensitive information were compromised, nor did it explain the delay between its discovery of the breach in July and its public announcement in early September. Equifax stated that the delay was due to the time needed to determine the scope of the intrusion and the large amount of personal data involved.

It was also revealed that three Equifax executives sold almost \$1.8 million of their personal holdings of company shares days after Equifax discovered the breach but more than a month before the breach was made public. The company said the executives, including the chief financial officer John Gamble, "had no knowledge that an intrusion had occurred at the time

they sold their shares". On September 18, Bloomberg reported that the U.S. Justice Department had opened an investigation to determine whether or not insider trading laws had been violated. "As Bloomberg notes, these transactions were not pre-scheduled trades and they took place on August 2, three days after the company learned of the hack".

When publicly revealing the intrusion to its systems, Equifax offered a website (<https://www.equifaxsecurity2017.com>) for consumers to learn whether they were victims of the breach. Security experts quickly noted that the website had many traits in common with a phishing website: it was not hosted on a domain registered to Equifax, it had a flawed TLS implementation, and it ran on WordPress which is not generally considered suitable for high-security applications. These issues led Open DNS to classify it as a phishing site and block access. Moreover, members of the public wanting to use the Equifax website to learn if their data had been compromised had to provide a last name and six digits of their social security number.

The website set up to check whether a person's personal data had been breached ([trustedidpremier.com](https://www.equifaxsecurity2017.com)) was determined by security experts and others to return apparently random results instead of accurate information. As with <https://www.equifaxsecurity2017.com>, this website, too, was registered and constructed like a phishing website, and it was flagged as such by several web browsers.

The Trusted ID Premier website contained terms of use, dated September 6, 2017 (the day before Equifax announced the security breach) which included an arbitration clause with a class action waiver. Attorneys said that the arbitration clause was ambiguous and that it could require consumers who accepted it to arbitrate claims related to the cybersecurity incident. According to Polly Mosendz and Shahien Nasiripour, "some fear[ed] that simply using an Equifax website to check whether their information was compromised bound them to arbitration". The [equifax.com](https://www.equifax.com) website has separate terms of use with an arbitration clause and class action waiver, but, according to Brian Fung of The Washington Post, "it's unclear if that

applies to the credit monitoring program". New York Attorney General Eric Schneiderman demanded that Equifax remove the arbitration clause. Responding to arbitration-related concerns, on September 8, Equifax issued a statement stating that "in response to consumer inquiries, we have made it clear that the arbitration clause and class action waiver included in the Equifax and TrustedID Premier terms of use does not apply to this cybersecurity incident". Joel Winston, a data protection lawyer, argued that the announcement disclaiming the arbitration clause "means nothing" because the terms of use state that they are the "entire agreement" between the parties. The arbitration clause was later removed from equifaxsecurity2017.com, and the equifax.com terms of use were amended on September 12 to state that they do not apply to www.equifaxsecurity2017.com, www.trustedidpremier.com, or www.trustedid.com and to exclude claims arising from those sites or the security breach from arbitration.

Responding to continuing public outrage, Equifax announced on September 12, 2017, that they "are waiving all Security Freeze fees for the next 30 days".

Equifax has been criticized by security experts for registering a new domain name for the site name instead of using a subdomain of equifax.com. On September 20, 2017, it was reported that Equifax had been mistakenly linking to an unofficial "fake" web site instead of their own breach notification site in at least eight separate tweets, unwittingly helping to direct a reported 200,000 hits to the imitation site. A software engineer named Nick Sweeting created the unauthorized Equifax web site to demonstrate how the official site could easily be confused with a phishing site. Sweeting's site was upfront to visitors that it was not official, however, telling visitors who had entered sensitive information that "you just got bamboozled! this isnt [sic] a secure site! Tweet to @equifax to get them to change it to equifax.com before thousands of people loose [sic] their info to phishing sites!" Equifax apologized for the "confusion" and deleted the tweets linking to this site.

See also

Chinese cyberwarfare

Chinese espionage in the United States

== References ==